SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL I-MCQ

COURSE CODE:ITA14 **COURSE NAME: Ethical Hacking**

Name	S.HARSHINI
Register Number	192S260084
Date	

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assessment Tool Weightage: 40%

Duration: 50 min Total Marks: 50

MCQ Questions

1. A company authorizes a security professional to test only its web server. During testing, the professional notices another vulnerable database server. What should the ethical hacker apply in this situation?
A) Test the database immediately
B) Remain within the authorized scope and report the observation
C) Exploit the database to verify the weakness
D) Download the database for analysis

2. A security tester receives written permission to assess a company network. Which action should the tester perform first to apply ethical hacking principles?
A) Launch vulnerability exploits
B) Review the authorized scope and rules of engagement
C) Disable the firewall
D) Collect employee passwords

3. An ethical hacker discovers confidential customer information during an authorized penetration test. How should the hacker apply confidentiality principles?
A) Copy the information to a personal device
B) Share it with other testers outside the project

C) Protect the information and follow the agreed reporting procedure
D) Publish the information as evidence

4. A student wants to practice vulnerability scanning on the college network. How should ethical hacking principles be applied?
A) Scan the network without informing anyone
B) Obtain authorization before performing the scan
C) Scan only during the night
D) Hide the source IP address

5. During an authorized assessment, a tester identifies a critical vulnerability. Which action applies responsible disclosure correctly?
A) Post the vulnerability publicly immediately
B) Report it securely to the authorized organization
C) Sell the information
D) Ignore the vulnerability

6. A penetration tester is authorized to test IP addresses 192.168.1.10–192.168.1.20. Which target can the tester ethically assess?
A) 192.168.1.5
B) 192.168.1.25
C) 192.168.1.15
D) 192.168.2.10

7. A tester accidentally gains access to sensitive payroll records during an assessment. What should the tester do?
A) Modify the records to demonstrate access
B) Download all records
C) Minimize further access and report the finding
D) Share screenshots publicly

8. A company asks an ethical hacker to assess its website without affecting normal users. Which approach should the hacker apply?
A) Perform only approved, controlled, non-destructive testing
B) Shut down the website
C) Delete vulnerable files
D) Modify customer accounts

9. An employee discovers a security flaw in the organization's internal application. How should proper disclosure be applied?
A) Publish the flaw online
B) Report it through the organization's approved security channel
C) Exploit the flaw repeatedly
D) Inform unrelated organizations

10. A tester is given authorization that expires at 6:00 PM. At 6:15 PM, testing is incomplete. What should the tester do?
A) Continue until testing is finished
B) Stop testing and obtain renewed authorization before continuing
C) Continue without recording the activity
D) Change the system time

11. A security professional wants to demonstrate the impact of a vulnerability. Which action best applies ethical hacking practice?
A) Cause maximum possible damage
B) Use the least harmful approved method to demonstrate the risk
C) Delete system files
D) Publish confidential data

12. A penetration tester discovers login credentials while performing an authorized assessment. How should the credentials be handled?
A) Store them publicly
B) Use them on unrelated systems
C) Protect them and use them only as permitted by the assessment scope
D) Share them with friends

13. A company permits testing of its web application but specifically prohibits denial-of-service testing. Which action should the tester take?
A) Perform denial-of-service testing anyway
B) Follow the restriction and avoid denial-of-service testing
C) Perform it outside office hours
D) Ask another person to perform it

14. An ethical hacker finds a vulnerability that could expose thousands of customer records. Which response correctly applies professional ethics?
A) Download all customer records
B) Document the vulnerability while minimizing exposure of customer data
C) Publish sample customer records
D) Use the data for another project

15. A tester realizes that a scanning tool is sending requests to systems outside the approved IP range. What should the tester do?
A) Allow the scan to continue
B) Stop or reconfigure the scan to remain within scope
C) Increase the scanning speed
D) Ignore the issue

16. An organization hires a penetration tester to evaluate its network. Which document should be applied to determine permitted and prohibited activities?
A) Rules of engagement

B) Employee attendance record
C) Software installation guide
D) Marketing report

17. A researcher discovers a vulnerability in a public website without prior authorization. What is the most appropriate ethical action?
A) Exploit it to determine its full impact
B) Avoid unauthorized exploitation and use the site's approved vulnerability-reporting process if available
C) Download user information
D) Change the vulnerable code

18. During testing, an ethical hacker finds evidence of an unexpected serious security issue. What should the hacker do?
A) Ignore it because it was unexpected
B) Follow the agreed escalation and reporting procedure
C) Delete the evidence
D) Publish the evidence immediately

19. A penetration tester completes an assessment and has temporary copies of sensitive data collected under authorization. What should be done according to the agreed data-handling policy?
A) Keep the data permanently
B) Transfer it to a personal computer
C) Securely retain or dispose of it according to the agreement
D) Share it with students

20. A tester needs to verify a vulnerability that could potentially crash a production server. Which action best applies ethical principles?
A) Test it immediately on the production server
B) Follow the approved testing procedure and use a safe environment where possible
C) Crash the server intentionally
D) Ignore all organizational restrictions

21. An ethical hacker is asked to test employee awareness using simulated phishing. What should be established before conducting the exercise?
A) Authorization, scope, and approved procedures
B) Employees' personal passwords
C) Access to personal email accounts
D) Permission from unrelated companies

22. A security tester discovers that the approved scope document contains unclear instructions about testing a particular server. What should the tester do?
A) Assume permission is granted
B) Obtain clarification before testing that server

C) Attack the server anonymously
D) Test first and ask later

23. During an authorized assessment, a tester identifies a weak password on an account. Which action appropriately applies ethical hacking principles?
A) Post the password online
B) Use it only as authorized and document the weakness
C) Use it to access unrelated accounts
D) Give it to other employees

24. A company asks a security professional to prepare a report after testing. Which information should be included to support ethical disclosure?
A) Vulnerabilities, evidence, risk, and recommended remediation
B) Personal opinions about employees
C) Unrelated customer information
D) Passwords for public distribution

25. A security team plans an ethical hacking assessment. Which sequence best applies ethical hacking principles?
A) Exploit → Obtain permission → Report → Define scope
B) Obtain authorization → Define scope → Test → Document → Report
C) Scan → Publish → Obtain permission → Exploit
D) Attack → Collect data → Share → Delete evidence

25. A senior security researcher is hired to test a decentralized cryptocurrency exchange. During the engagement, they notice a marketing team's standalone server is highly vulnerable. The tester decides to execute a remote code execution payload to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A. It is ethically sound because it improves the client's overall security posture.

B. It is valid under standard ethical hacking frameworks provided no data is permanently deleted.

C. It is legally protected as long as the tester does not monetize or leak the findings.

D. It violates explicit authorization, risking severe legal liability and breaching ethical boundaries.

26. While officially authorized to test a decentralized cryptocurrency exchange, An internal compliance auditor assumes the contract implicitly includes the building's physical security camera system and proceeds to attack it. Judge the legal validity of this assumption.

A. Ethically and legally dangerous; authorization must always be explicit, docu

mented,and unambiguous.

B. Itislegallypermissibleaslongastheactorisacertifiedandlicensedprofessional.

C. Itisstandardpracticetoensurenoblindspotsremainintheclient'soverallaudit.

D. Itisavalidassumptionifbothsystemssharethesameinternall Psubnet.

27. An independent ethical hacker is offered a contract to audit a federal tax web portal, but theyrecentlywasrejectedforafull-timeroletherelastweek.Judgethedecisiontoacceptthis auditing contract.

A. Unethicalduetoasevereconflictofinterestthatcompromisestheauditor'sobjectivity.

B. Legalandethical,providedtheysignasupplementarynon-disclosureagreement.

C. Acceptable,aslongastheyonlyutilizeautomatedscanningtoolstoremovebias.

D. Ethical,astheirinsiderknowledgewillresultinamorethoroughsecuritytest.

28. Followinganengagementagainstamulti-nationalbank'smobileapp,managementstrictly asks A corporate security consultant to delete any mention of the CEO's compromised email account in the final official report. Recommend the most ethical response.

A. Alterthereportasrequested,butleaveahiddencryptographicsignatureindicatingtampering.

B. Refusetherequestentirelytomaintaintheintegrity,accuracy,andobjectivityoftheaudit.

C. Agreetothemodification,butchargeapremiumfeeforalteringofficialcompliancedocuments

D. Complywiththerequest,astheclientownsthereportandretainsfinaleditorialrights.

29. Months after successfully finishing a penetration test on a decentralized cryptocurrency exchange,Aninternalcomplianceauditordecidestoretainthedatabaseofunencryptedcredit cardtransactionsonalocalhomeserver'justincase'.Critiquethispost-engagementpractice.

A. Itblatantlyviolatestheethicalmandateforsecuredatadestructionandstrictconfidentiality.

B. Itisethicallyacceptableaslongasthehomeserverisdisconnectedfromthepublicinternet.

C. Itisastandardindustrypracticetoretainclientdataforlong-termhistoricalbenchmarking.

D. Itislegallyrequiredtoprovethevulnerabilitiesexistedincaseofafutureauditdispute.

30. A network security auditor is offered a contract to audit a logistics and shipping API, but theyrecentlyissecretlybuildingacompetingsoftwareproduct.Judgethedecisiontoaccept this auditing contract.

A. Unethicalduetoasevereconflictofinterestthatcompromisestheauditor'sobjectivity.

B. Ethical,astheirinsiderknowledgewillresultinamorethoroughsecuritytest.

C. Legalandethical,providedtheysignasupplementarynon-disclosureagreement.

D. Acceptable,aslongastheyonlyutilizeautomatedscanningtoolstoremovebias.

31. During a monitoring phase, A corporate security consultant detects an active, malicious attackoriginatingagainstanonlineretailplatform.Theyimmediatelyrespondbydeployin ga reverse-shell to delete the attacker's tools. Judge this defensive response.

A. Itislegallyprotectedunderinternationalself-defensedoctrinesfordigitalproperty.

B. Itisethicallymandatedtopreventfurtherharmtotheclient'snetworkinfrastructure.

C. Itisacceptableiflocallawenforcementisnotifiedwithin24hoursofthecounter-attack.

D. Itisillegalvigilantism(hackingback);ethicalhackingdoesnotauthorizeoffensiveactio nsagainst third parties.

32. Monthsaftersuccessfullyfinishingapenetrationtestonauniversity'sresearchdatabase,A bug bounty participant decides to retain the medical records accessed during the test on alocalhomeserver'justincase'.Critiquethispost-engagementpractice.

A. Itislegallyrequiredtoprovethevulnerabilitiesexistedincaseofafutureauditdispute.

B. Itisethicallyacceptableaslongasthehomeserverisdisconnectedfromthepublicinternet.

C. Itisastandardindustrypracticetoretainclientdataforlong-termhistoricalbenchmarking.

D. Itblatantlyviolatestheethicalmandateforsecuredatadestructionandstrictconfidentiality.

33. While officially authorized to test a public transportation control system, A junior penetrationtesterassumesthecontractimplicitlyincludesastagingserverthatcloselymirrors production and proceeds to attack it. Judge the legal validity of this assumption.

A. Itislegallypermissibleaslongastheactorisacertifiedandlicensedprofessional.

B. Ethicallyandlegallydangerous;authorizationmustalwaysbeexplicit,docu mented,and unambiguous.

C. Itisstandardpracticetoensurenoblindspotsremainintheclient'soverallaudit.

D. Itisavalidassumptionifbothsystemssharethesameinternal IPsubnet.

34. Aninternalcomplianceauditorisofferedacontracttoauditaregionalhospital'snetwork, but they recently has a lucrative side-deal with their top competitor to leak data. Judge the decision to accept this auditing contract.

A. Ethical,astheirinsiderknowledgewillresultinamorethoroughsecuritytest.

B. Legalandethical,providedtheysignasupplementarynon-disclosureagreement.

C. Acceptable,aslongastheyonlyutilizeautomatedscanningtoolstoremovebias.

D. Unethicalduetoasevereconflictofinterestthatcompromisestheauditor'sobjectivity.

35. Acorporatesecurityconsultantidentifiesavulnerabilityinanonlineretailplatformwitho ut any prior permission and creates a video showing the hack but hides the company name. Classify the hacker profile and evaluate the action.

A. Hacktivism;aimedatpoliticalreformbyexposingthecompany'sweaksecurityposture.

B. Blackhatbehavior;drivenstrictlybymaliciousintentandviolationoftheCIAtriad.

C. Grayhatbehavior;well-intentionedbutlegallyperilousduetothestrictlackofauthorization.

D. Whitehatbehavior;entirelyethicalandlegalsincetheultimategoalwassystemdefense.

36. An internal compliance auditor identifies a vulnerability in a regional hospital's network
withoutanypriorpermissionandfixestheflawbutleavesaharmlessbackdoorforthemselves. Classify the hacker profile and evaluate the action.

A. Whitehatbehavior;entirelyethicalandlegalsincetheultimategoalwassystemdefense.

B. Hacktivism;aimedatpoliticalreformbyexposingthecompany'sweaksecurityposture.

C. Grayhatbehavior;well-intentionedbutlegallyperilousduetothestrictlackofauthorization.

D. Blackhatbehavior;drivenstrictlybymaliciousintentandviolationoftheCIAtriad.

37. During a monitoring phase, An independent ethical hacker detects an active, malicious
attackoriginatingagainstafederaltaxwebportal.Theyimmediatelyrespondbywipingt he attacker's database of stolen credentials. Judge this defensive response.

A. Itisillegalvigilantism(hackingback);ethicalhackingdoesnotauthorizeoffensiveactio nsagainst third parties.

B. Itislegallyprotectedunderinternationalself-defensedoctrinesfordigitalproperty.

C. Itisacceptableiflocallawenforcementisnotifiedwithin24hoursofthecounter-attack.

D. Itisethicallymandatedtopreventfurtherharmtotheclient'snetworkinfrastructure

38. WhileassessingalogisticsandshippingAPI,Anetworksecurityauditorrunsacustomize d payload generator without verifying its impact, which inadvertently locks out all legitimate administrative users. Assess the primary ethical failure in this scenario.

A. AbreachofNon-repudiation,asthetool'sexecutionlogswerenotpreserved.

B. Failuretoassessoperationalrisk,directlyviolatingtheprincipleofAvailability.

C. AviolationofConfidentiality,asthesystemoutagelikelyexposedunencrypteddata.

D. Thereisnoethicalfailure,asuncoveringdeepvulnerabilitiesinherentlyrequiresdowntime.

39. Upon discovering a severe flaw in a cloud storage provider, A network security auditor contactstheorganizationanddemands$50,000inEthereumbeforeprovidingthevulnerabil ity report. Evaluate this action under ethical hacking laws.

A. Itisethicallyjustifiediftheorganizationcaneasilyaffordtherequestedcompensation.

B. Thisisanaggressivebutlegallyrecognizednegotiationtacticwithinmodernbugbounties.

C. Thisconstitutesillegalextortionandisclassifiedasmaliciousblack-hatbehavior.

D. Itisvalidunderfulldisclosureguidelinesascompensationfortheresearcher'stime.

40. Whileassessinganonlineretailplatform,Acorporatesecurityconsultantrunsamas s exploitation script without verifying its impact, which inadvertently crashes the primary production database. Assess the primary ethical failure in this scenario.

A. Thereisnoethicalfailure,asuncoveringdeepvulnerabilitiesinherentlyrequiresdowntime.

B. AviolationofConfidentiality,asthesystemoutagelikelyexposedunencrypteddata.

C. Failuretoassessoperationalrisk,directlyviolatingtheprincipleofAvailability.

D. AbreachofNon-repudiation,asthetool'sexecutionlogswerenotpreserved.

41. Following an engagement against a federal tax web portal, management strictly asks A

freelancevulnerabilityassessortofalsifythedateofthetesttomeetaregulatorydeadlinein the final official report. Recommend the most ethical response.

A. Alterthereportasrequested,butleaveahiddencryptographicsignatureindicatingtampering.

B. Complywiththerequest,astheclientownsthereportandretainsfinaleditorialrights.

C. Agreetothemodification,butchargeapremiumfeeforalteringofficialcompliancedocuments.

D. Refusetherequestentirelytomaintaintheintegrity,accuracy,andobjectivityoftheaudit.

42. A bug bounty participant is offered a contract to audit a social media startup, but they recentlyiscurrentlysuingthecompanyforwrongfultermination.Judgethedecisiontoaccept this auditing contract.

A. Unethicalduetoasevereconflictofinterestthatcompromisestheauditor'sobjectivity.

B. Acceptable,aslongastheyonlyutilizeautomatedscanningtoolstoremovebias.

C. Ethical,astheirinsiderknowledgewillresultinamorethoroughsecuritytest.

D. Legalandethical,providedtheysignasupplementarynon-disclosureagreement.

43. Whileofficiallyauthorizedtotestalogisticsandshipping API,Aseniorsecurityresearcher assumes the contract implicitly includes a third-party managed database physically located in the office and proceeds to attack it. Judge the legal validity of this assumption.

A. Itisavalidassumptionifbothsystemssharethesameinternal IP subnet.

B. Ethicallyandlegallydangerous;authorizationmustalwaysbeexplicit,documented,and unambiguous.

C. Itisstandardpracticetoensurenoblindspotsremainintheclient'soverallaudit.

D. Itislegallypermissibleaslongastheactorisacertifiedandlicensedprofessional.

44. A certified red teamer is hired to test a university's research database. During the engagement,theynoticeaphysicallyseparateHRnetworkishighlyvulnerable.Thetester decides to deploy a ransomware simulator on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A. Itislegallyprotectedaslongasthetesterdoesnotmonetizeorleakthefindings.

B. Itisethicallysoundbecauseitimprovestheclient'soverallsecurityposture.

C. Itisvalidunderstandardethicalhackingframeworksprovidednodataispermanentlydeleted.

D. Itviolatesexplicitauthorization,riskingseverelegalliabilityandbreachingethicalboundaries

45. Duringamonitoringphase,Afreelancevulnerabilityassessordetectsanactive,malicio us attack originating against a university's research database. They immediately respond by launching a DDoS attack against the attacker's IP. Judge this defensive response.

A. Itislegallyprotectedunderinternationalself-defensedoctrinesfordigitalproperty.

B. Itisacceptableiflocallawenforcementisnotifiedwithin24hoursofthecounter-attack.

C. Itisillegalvigilantism(hackingback);ethicalhackingdoesnotauthorizeoffensiveactio nsagainst third parties.

D. Itisethicallymandatedtopreventfurtherharmtotheclient'snetworkinfrastructure.

46. Following an engagement against a cloud storage provider, management strictly asks A networksecurityauditortochangetherootcausefrom'negligence'to'advancedthreat'inthe final official report. Recommend the most ethical response.

A. Agreetothemodification,butchargeapremiumfeeforalteringofficialcompliancedocuments .

B. Alterthereportasrequested,butleaveahiddencryptographicsignatureindicatingtampering.

C. Refusetherequestentirelytomaintaintheintegrity,accuracy,andobjectivityoftheaudit.

D. Complywiththerequest,astheclientownsthereportandretainsfinaleditorialrights.

47. AfterdiscoveringacriticalflawinabiometricauthenticationAPI,Afreelancevulnerab ility assessor reports it privately. The vendor ignores the report for 9 months. Frustrated, the researcher decides to upload an automated exploitation script to GitHub. Critique this disclosure strategy.

A. ItisethicalaspartoftheCoordinatedDisclosureframeworksincethegraceperiodexpired.

B. Itisunethicalasitmaximizesrisktothepublicwithoutprovidingaviablemitigationpath.

C. Itislegallyacceptablebecausethevendor'ssilenceautomaticallywaivestheircopyrightprote

ctions.

D. ItiscompletelyjustifiedundertheFullDisclosuremodeltoforcethevendorintoaction.

48. A network security auditor is hired to test a social media startup. During the engagement, theynoticeadeactivatedtestenvironmentishighlyvulnerable.Thetesterdecidestocreatea new administrative account on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A. Itisvalidunderstandardethicalhackingframeworksprovidednodataispermanentlydeleted.

B. Itviolatesexplicitauthorization,riskingseverelegalliabilityandbreachingethicalboundaries .

C. Itisethicallysoundbecauseitimprovestheclient'soverallsecurityposture.

D Itislegallyprotectedaslongasthetesterdoesnotmonetizeorleakthefindings

49. Monthsaftersuccessfullyfinishingapenetrationtestonaregionalhospital'snetwork,A n independentethicalhackerdecidestoretainacompletedumpofthecustomerdatabaseona local home server 'just in case'. Critique this post-engagement practice.

A. Itislegallyrequiredtoprovethevulnerabilitiesexistedincaseofafutureauditdispute.

B. Itisethicallyacceptableaslongasthehomeserverisdisconnectedfromthepublicinternet.

C. Itisastandardindustrypracticetoretainclientdataforlong-termhistoricalbenchmarking.

D Itblatantlyviolatestheethicalmandateforsecuredatadestructionandstrictconfidentiality

50. A senior security researcher identifies a vulnerability in a public transportation control systemwithoutanypriorpermissionandanonymouslysubmitsthefindingtoapublicbu g tracker. Classify the hacker profile and evaluate the action.

A. Whitehatbehavior;entirelyethicalandlegalsincetheultimategoalwassystemdefense.

B. Hacktivism;aimedatpoliticalreformbyexposingthecompany'sweaksecurityposture.

C. Blackhatbehavior;drivenstrictlybymaliciousintentandviolationoftheCIAtriad.

D Grayhatbehavior;well-intentionedbutlegallyperilousduetothestrictlackofauthorization.

Code of Conduct:

I S.HARSHINI 192502608 *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.I understand that any violation of academic integrity rules will result in disciplinary action.*

S.Harshini

Signature of the student:

RUBRICS FOR CALCULATION:

Criteria	**Weightage (%)**	**Level 4 (Exemplary)**	**Level 3 (Proficient)**	**Level 2 (Developing)**	**Level 1 (Beginning)**
Conceptual Understanding	30%	Demonstrates thorough understanding; answers all questions accurately	Shows good understanding with few errors	Partial understanding; several incorrect responses	Lacks understanding; majority of answers incorrect
Accuracy of Answers	25%	All answers are correct	Most answers are correct with minor mistakes	Some correct answers; frequent errors	Mostly incorrect answers

Application of Knowledge	20%	Correctly applies concepts to problem-based questions	Applies concepts with minor errors	Limited ability to apply concepts	Unable to apply concepts
Time Management	15%	Completes quiz well within time efficiently	Completes on time with minor delays	Requires extra time or rushes through questions	Unable to complete within given time
Question Interpretation	10%	Interprets all questions correctly and responds appropriately	Misinterprets a few questions	Often misinterprets questions	Unable to understand questions